



Security, Compliance and Governance for AI Solutions

Introduction

Governance and Compliance for AI Systems

- AI governance involves ensuring ethical, transparent, and compliant use of AI through strategies like data privacy, fairness, accountability, and risk management.
- AWS supports this with services such as SageMaker Clarify, AWS CloudTrail, and IAM, enabling policy enforcement, data protection, and continuous monitoring.

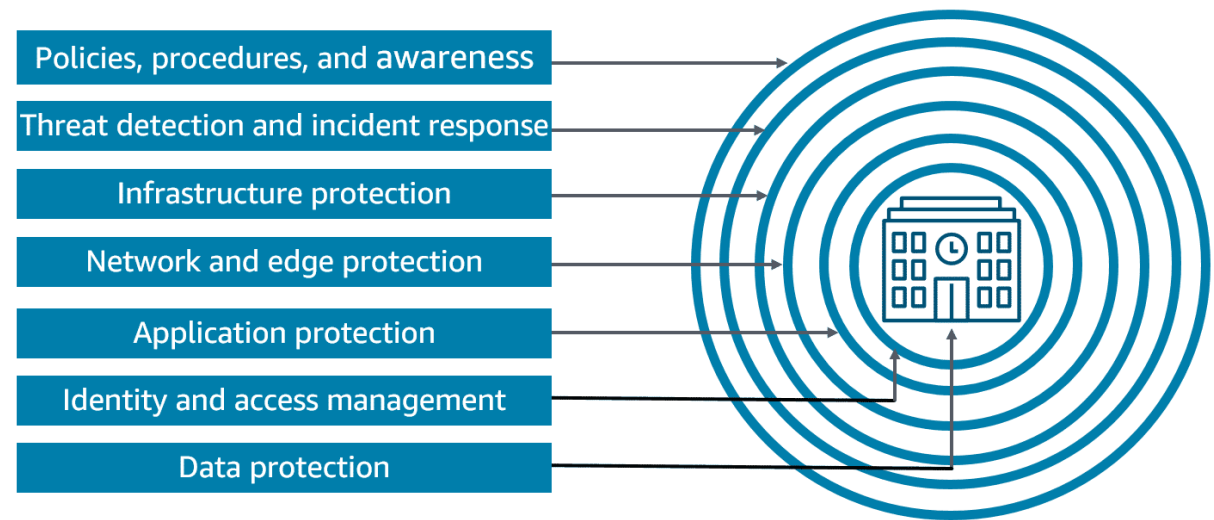
Securing AI Systems

- Securing AI systems involves addressing key considerations such as data privacy, model integrity, access control, and traceability through practices like documenting data origins, citing sources, and implementing secure data pipelines.
- AWS provides tools like IAM (identity management), Amazon Macie (sensitive data detection), AWS KMS (encryption), and SageMaker Model Monitor to enforce secure, compliant AI development and deployment.

Strategic Guidance for Security, Governance, and Compliance

Defense in depth for AI on AWS

This course focuses on one of the most common paradigms, known as defense in depth, that organizations follow to integrate their security, governance, and compliance functions while building on AWS. Here are some features:



Compliance Standards for AI Systems

AWS Compliance

AWS compliance empowers customers to understand the robust controls in place at AWS to maintain security and data protection in the AWS Cloud. AWS supports 143 security standards and compliance certifications.

National Institute of Standards and Technology (NIST)
European Union Agency for Cybersecurity (ENISA)
International Organization for Standardization (ISO)
AWS System and Organization Controls (SOC)
Health Insurance Portability and Accountability Act (HIPAA)
General Data Protection Regulation (GDPR)
Payment Card Industry Data Security Standard (PCI DSS)

AWS Services for Governance and Compliance

AWS has many services and features to assist with governance and regulation compliance. The following is a brief description of some of the key services.

AWS Config

- AWS Config offers a detailed, historical view of your AWS resource configurations and their relationships, allowing you to track changes over time.
- It helps manage and monitor growing AWS environments by maintaining visibility and compliance across all resources used in your applications.

Amazon Inspector Summary:

- Amazon Inspector is a vulnerability management service that continuously scans AWS workloads – like EC2 instances, container images, and Lambda functions – for software vulnerabilities and network exposure.
- It automatically generates findings when issues are detected, helping maintain the security and compliance of your AWS environment.

AWS Services for Governance and Compliance

AWS Artifact

- AWS Artifact offers on-demand access to security and compliance documents like ISO certifications, PCI, and SOC reports, which can be used to support audits and regulatory requirements.
- While AWS provides infrastructure-level compliance, customers are responsible for demonstrating the security and compliance of their own applications and data under the Shared Responsibility Model.

AWS CloudTrail Summary:

- AWS CloudTrail records actions across your AWS environment – whether through the console, CLI, SDKs, or APIs – supporting auditing, governance, and compliance.
- It provides detailed visibility into account activity, allowing you to track who did what, when, and on which resources, helping with security analysis and incident response.

AWS Services for Governance and Compliance

AWS Audit Manager Summary:

- AWS Audit Manager automates the continuous auditing of your AWS environment to simplify risk and compliance management with industry standards and regulations.
- It streamlines evidence collection and supports stakeholder reviews to evaluate the effectiveness of your security and compliance controls during audits.

AWS Trusted Advisor Summary:

- AWS Trusted Advisor continuously evaluates your AWS environment against best practices in areas like cost optimization, performance, resilience, security, and operational excellence.
- It provides actionable recommendations to help reduce costs, enhance security, improve performance, and ensure your environment scales reliably.

Data Governance Strategies

Concepts in Data Governance

Data lifecycle in AI workloads involves managing data from creation through stages like collection, processing, storage, consumption, and finally disposal or archiving.

Data logging is the systematic recording of inputs, outputs, performance metrics, and system events in AI workloads, enabling effective debugging, monitoring, and insight into system behaviour.

Data residency refers to the physical location of data storage and processing, with AI workloads needing to consider compliance with privacy laws, data sovereignty, and proximity to compute resources for training and inference.

Data monitoring is the continuous analysis of AI workload data to ensure quality, detect anomalies, and track data drift, helping maintain the relevance and accuracy of training and inference over time.

Approaches for Implementing Governance Strategies

Governance Strategies

Establish and follow governance strategies to ensure responsible development and deployment. The following are some key approaches to consider.

- Policies
- Review cadence
- Review strategies
- Transparency standards
- Team training requirements

Monitoring AI System

Performance Metrics

Monitor the performance of the AI system by tracking metrics, such as the following:

- **Model accuracy:** The proportion of correct predictions made by the model
- **Precision:** The ratio of true positive predictions to the total number of positive predictions made by the model
- **Recall:** The ratio of true positive predictions to the total number of actual positive instances in the data
- **F1-score:** The harmonic mean of precision and recall, which provides a balanced measure of model performance
- **Latency:** The time taken by the model to make a prediction, which is an important measure of a model's practical performance

Infrastructure Monitoring

Monitor the underlying infrastructure that supports the AI system, including the following:

- Compute resources (for example, CPU, memory, GPU)
- Network performance
- Storage
- System logs
- This can help you identify resource bottlenecks, capacity planning issues, and potential system failures.

Performance Metrics

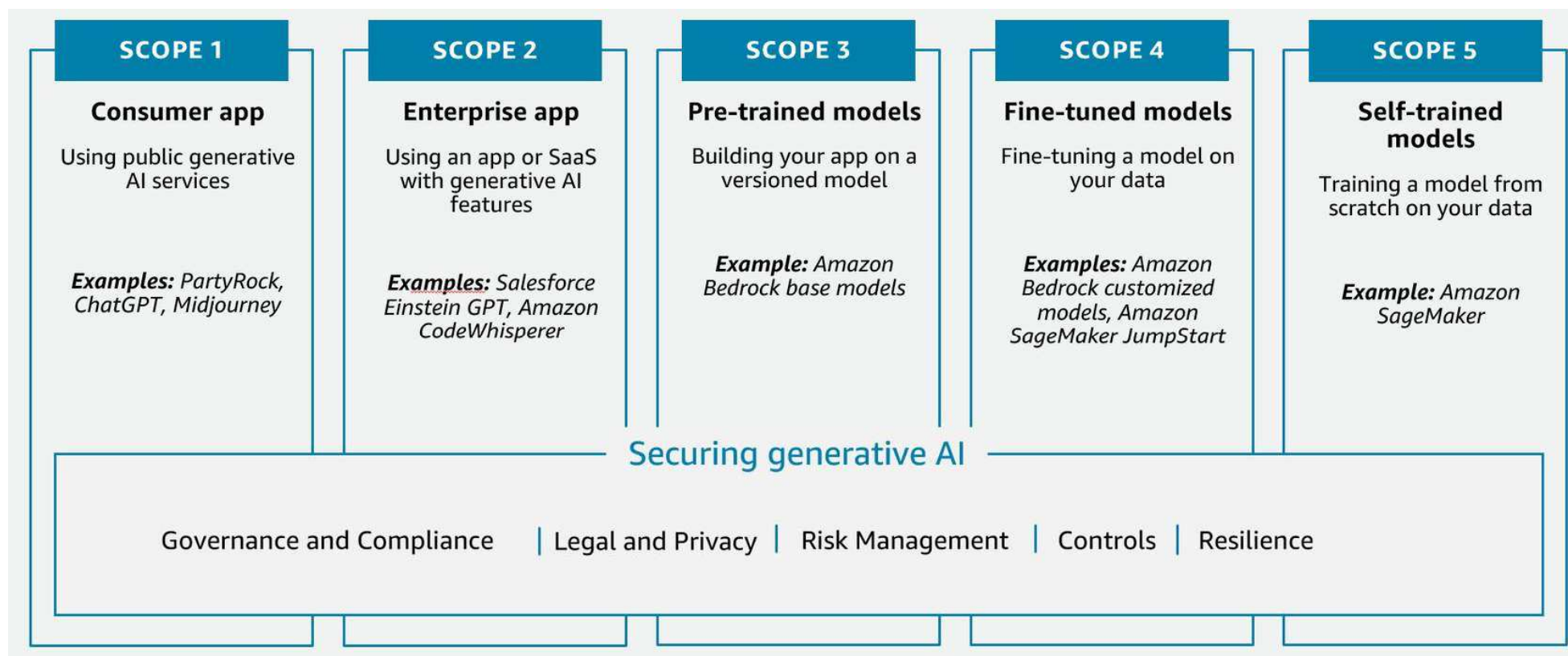
Monitoring for Bias and Fairness

Monitoring for bias and fairness involves routinely evaluating AI systems – particularly in sensitive areas like healthcare, finance, and HR – to detect and mitigate biased or unfair outcomes, ensuring equitable and responsible decision-making.

Monitoring for Compliance and Responsible AI

Continuously evaluate AI outputs to ensure alignment with regulations and ethical standards, while identifying and addressing any potential compliance or fairness issues.

Generative AI Security Scoping Matrix



Securing AI Systems

Security Considerations

- Threat detection
- Vulnerability management
- Infrastructure protection
- Prompt injection
- Data encryption

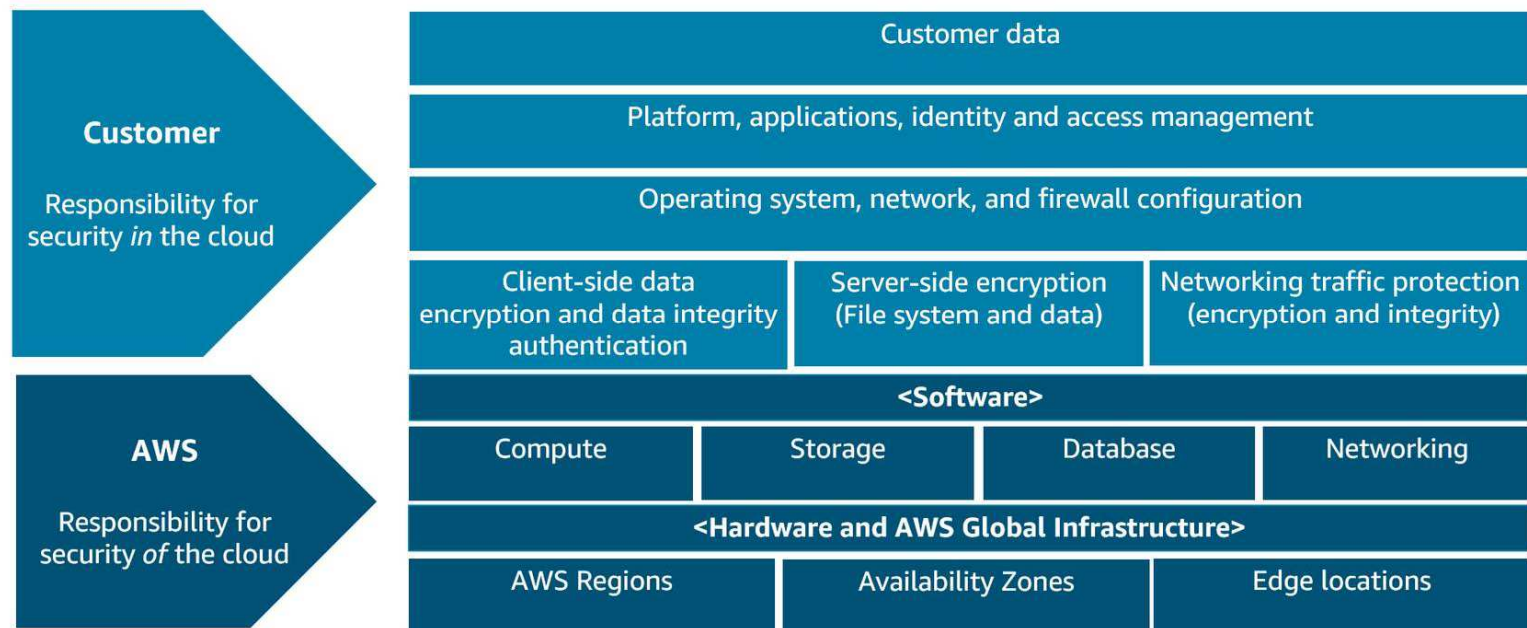
The Open Web Application Security Project (OWASP) Top 10 is the industry standard list of the top 10 vulnerabilities that can impact a generative AI LLM system.

<https://owasp.org/www-project-top-ten/>

AWS Services and Features for Securing AI Systems

Shared Responsibility Model Summary:

- AWS is responsible for managing the physical infrastructure, virtualization layer, and foundational services, reducing the customer's operational burden.
- Customers are responsible for securing their data, applications, guest operating systems, and configuring services like firewalls and updates.



AWS Services and Features for Securing AI Systems



AWS Security Hub



AWS KMS



Amazon GuardDuty



AWS Shield
Advanced

There are four foundational AWS security services recommended for any workload, any customer, and any industry.

- AWS Security Hub provides customers with a single dashboard to view all security findings, and to create and run automated playbooks.
- AWS KMS encrypts data and gives customers the choice and control of using AWS managed keys or customer-managed keys to protect their data.
- Amazon GuardDuty is a threat detection service that monitors for suspicious activity and unauthorized behavior to protect AWS accounts, workloads, and data.
- AWS Shield Advanced helps protect workloads against Distributed Denial of Service (DDoS) events. AWS Shield Advanced includes AWS WAF and AWS Firewall Manager.

Understanding Data and Model Lineage

- Data and model lineage refer to the detailed record of the origin, transformation, and evolution of data and models used in AI and generative AI systems.
- This information is important for understanding the origin, reliability, and potential biases or limitations of the data and models used in these systems.
 - Source citation
 - Documenting data origins

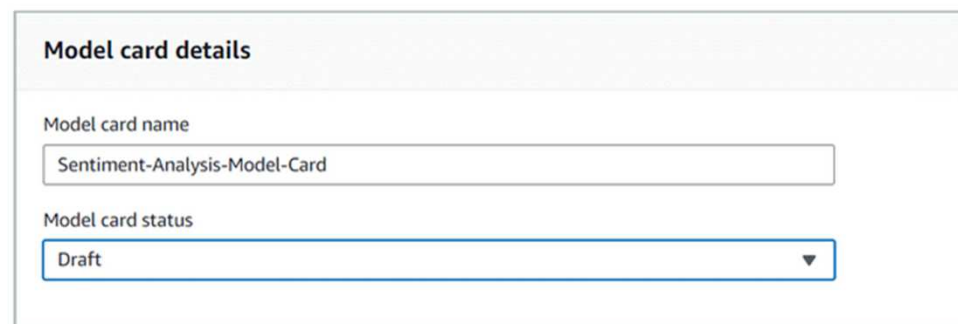
Tools and techniques

- Data lineage; track the history of data, including its origin, transformation, and movement through different systems.
- Cataloging; systematic organization and documentation of the datasets, models, and other resources used to develop a generative AI system
- Model cards; standardized format for documenting the key details about an ML model, including its intended use, performance characteristics, and potential limitations.

Understanding Data and Model Lineage

Amazon SageMaker Model Cards

- You can use Amazon SageMaker Model Cards to document critical details about your ML models in a single place for streamlined governance and reporting.
- Provide guidance on how a model should be used.
- Support audit activities with detailed descriptions of model training and performance.
- Communicate how a model is intended to support business goals.



The image shows a screenshot of the 'Model card details' form in the Amazon SageMaker console. The form is titled 'Model card details' and contains two input fields. The first field is labeled 'Model card name' and contains the text 'Sentiment-Analysis-Model-Card'. The second field is labeled 'Model card status' and is a dropdown menu with 'Draft' selected. The form is enclosed in a light gray border.

Model card details	
Model card name	Sentiment-Analysis-Model-Card
Model card status	Draft

Knowledge Check

Q1.

A company has implemented a generative AI solution that a US federal information system will use. The developers need to ensure sufficient protection of confidentiality, integrity, and availability of the information that their solution accesses.

Which of the following standards should they comply with for the US government?

- A. National Institute of Standards and Technology (NIST)
- B. General Data Protection Regulation (GDPR)
- C. Payment card industry data security standard (PCI-DSS)
- D. AWS System and Organization Controls (SOC)

Knowledge Check

Q1.

A company has implemented a generative AI solution that a US federal information system will use. The developers need to ensure sufficient protection of confidentiality, integrity, and availability of the information that their solution accesses.

Which of the following standards should they comply with for the US government?

- A. National Institute of Standards and Technology (NIST)**
- B. General Data Protection Regulation (GDPR)
- C. Payment card industry data security standard (PCI-DSS)
- D. AWS System and Organization Controls (SOC)

Q2.

A financial institute is exploring artificial intelligence (AI)-based solutions for a customer-facing web application. They are considering some products that are available through the AWS Marketplace. The financial institute needs to perform due diligence of independent software vendors (ISVs) that sell products on AWS Marketplace, and access security and compliance reports.

Which AWS service can this company use to help with this task?

- A. AWS CloudTrail
- B. AWS Artifact
- C. Amazon Inspector
- D. AWS Config

Q2.

A financial institute is exploring artificial intelligence (AI)-based solutions for a customer-facing web application. They are considering some products that are available through the AWS Marketplace. The financial institute needs to perform due diligence of independent software vendors (ISVs) that sell products on AWS Marketplace, and access security and compliance reports.

Which AWS service can this company use to help with this task?

- A. AWS CloudTrail
- B. AWS Artifact**
- C. Amazon Inspector
- D. AWS Config

Q3.

An organization has implemented some generative AI workloads and understands the need for data governance strategies.

What are some key strategies they might consider to manage their data? (Select TWO.)

- A. Data transcription, translation, batch processing
- B. Data monitoring processes, data observation techniques, data retention
- C. Distributed, real-time, and parallel processing
- D. Data lifecycles, data logging processes, data residency
- E. Online transaction processing (OLTP)

Q3.

An organization has implemented some generative AI workloads and understands the need for data governance strategies.

What are some key strategies they might consider to manage their data? (Select TWO.)

- A. Data transcription, translation, batch processing
- B. Data monitoring processes, data observation techniques, data retention**
- C. Distributed, real-time, and parallel processing
- D. Data lifecycles, data logging processes, data residency**
- E. Online transaction processing (OLTP)

Q4.

A company has several AI systems that involve different levels of generative AI solutions, such as pre-trained models and fine-tuned models. The developers need to follow governance strategies to ensure responsible development and deployment.

What are some governance strategies that they might consider? (Select TWO.)

- A. Monitor the underlying infrastructure that supports the artificial intelligence (AI) system.
- B. Develop clear policies relating to the organization's approach to generative artificial intelligence (AI).
- C. Implement security controls that are used to mitigate risk.
- D. Monitor the performance of the artificial intelligence (AI) system by tracking metrics, such as model accuracy.
- E. Maintain high standards of transparency in the development of their solutions.

Q4.

A company has several AI systems that involve different levels of generative AI solutions, such as pre-trained models and fine-tuned models. The developers need to follow governance strategies to ensure responsible development and deployment.

What are some governance strategies that they might consider? (Select TWO.)

- A. Monitor the underlying infrastructure that supports the artificial intelligence (AI) system.
- B. Develop clear policies relating to the organization's approach to generative artificial intelligence (AI).**
- C. Implement security controls that are used to mitigate risk.
- D. Monitor the performance of the artificial intelligence (AI) system by tracking metrics, such as model accuracy.
- E. Maintain high standards of transparency in the development of their solutions.**